情報処理安全確保支援士試験　科目B　技能1〜4　事例演習　#24

科目B 事例演習

事例の文章から、根拠を拾って選ぶ

各ページの下に、根拠にした資料（IPA の支援士試験シラバス案【目標とする技能】、IPA 科目Bのサンプル問題、IPA「安全なウェブサイトの作り方」、JIS Q 27001・27002、個人情報保護法、RFC 3227 など）を書いた。サンプル問題以外の会社・ログの例は Claude が作った

全体像 シラバス案【目標とする技能】大項目1〜4

科目Bの形（IPA サンプル問題）

形	問数
1 問 1 答（設問 1 つ）	8 問
1 問 3 答（設問 3 つ、全部必須）	4 問

> 解答群は 6〜8 個。「A／B／C の組合せ」の形が多く、一つでも違えば誤り。

1 マネジメント
方針、リスクアセスメントと対応、規程、点検、委託先、法令、人的管理、監査、情報収集

2 ライフサイクル
要件定義、製品の導入、設計、実装、セキュアプログラミング、テスト・診断、運用、開発環境

3 対策の適用
暗号と鍵、マルウェア、データ保護、監視、ネットワーク、脆弱性管理、物理、アカウント

4 インシデント管理
体制、検知と初動、原因究明と再発防止、証拠の収集と分析

出典：IPA「情報処理安全確保支援士試験 科目Bのサンプル問題」／IPA「支援士試験 シラバス（案）Ver.0.1」【目標とする技能】

事例問題の読み方

1 設問を先に読む
何を選ぶか（空欄の記号、組合せの順）

→

2 本文の表と注記
定義・条件・例外は表の説明と注記にある

→

3 根拠の行に印
「同一であった」「施されていない」

→

4 組合せは一つずつ
確実な要素から選択肢を消す

サンプル問1 の「重要度」は「最大値」と表に書いてある。自分の知識の式でなく、問題文の定義で計算する。

支援士は「助言・支援する」立場。承認・受容・決定は経営者やリスク所有者がする。選択肢の主語に注意。

出典：IPA 科目Bのサンプル問題 問1・問2／シラバス案 技能の概要「必要な指導・助言を行い，支援する」

第1章

マネジメントの事例

台帳を正しく作り、リスクの持ち主に決めてもらう。

サンプル問1：情報資産台帳

台帳の項目（抜粋）

管理部署	情報資産を管理する部署
C・I・A の評価値	各 0〜2 の 3 段階
重要度	**C・I・A の最大値**
注記	管理方法や評価値が**全て同じ**ならまとめてよい

経理部の質問と答え

1 開示済みと作成中の決算短信をまとめてよいか
機密性が 0 と 2 で違う → してはいけない

2 情報システム部のサーバにある債権管理情報の管理部署は
中身に責任を持つ → 経理部

3 C・I・A が 0・1・2 の重要度は
最大値 → 2

> 正解は「してはいけない／経理部／2」（原文の解答群ではオ）。

出典：IPA「情報処理安全確保支援士試験 科目Bのサンプル問題」問1・解答例

リスクの判断は誰がするか

支援士
計画の案・助言

→

リスク所有者
計画と残留リスクを承認

リスク所有者
リスクを運用管理する説明責任と権限を持つ人（JIS Q 27000）

残留リスク
対応のあとに残るリスク。0 にはならない

情報セキュリティ方針（基本方針）を承認するのはトップマネジメント（5.2）。

リスク値＝重要度 × 脅威 × 脆弱性（例）

資産	重	脅	脆	値
顧客 DB	3	2	1	6
社内 Wiki	1	3	3	9
受発注システム	3	2	2	12
公開 Web	2	3	1	6

重要度が最大の資産が、リスク値も最大とは限らない。

出典：JIS Q 27001:2023 5.2・6.1.3 f)／JIS Q 27000 リスク所有者／シラバス案 技能1-1〜1-3（リスク値の表は例として作った）

委託先と人の管理

委託先の監督（個人情報保護法 第25条）

適切な委託先を選ぶ

委託契約を結ぶ
安全管理措置、再委託の条件、監査・報告の権利、終了時の返却・消去

取扱状況を把握する

再委託は事前の承諾を条件に。再委託先にも同等の義務。委託先が監督しているかも確かめる。

退職・異動（JIS Q 27002）

申出
権限を必要な範囲に絞る・操作記録を確認

→

退職日
資産の返却（5.11）・アカウント削除（5.18）

→

退職後
守秘の義務は続く（6.5）

アカウントの貸し借り・共有アカウントは、誰の操作か分からなくなる。

訓練の指標は目的に合わせる。「早く知らせる」なら報告率と報告までの時間。

出典：個人情報保護法 第25条・ガイドライン（通則編）3-4-4／JIS Q 27002:2024 5.11・5.18・6.5／IPA「組織における内部不正防止ガイドライン」／シラバス案 技能1-6・1-8

第2章

ライフサイクルとWeb診断の事例

画面遷移図を読み、どこで何が起きるかを特定する。

サンプル問2：画面遷移と sessionID

01 ログイン
https://test.△△△.jp/

（イ）→

02 求人企業トップ
URL は 01 と同じ

（エ）→

03 マイページ
https://test.△△△.jp/mypage

診断で分かったこと

```
01 を直接表示   sessionID=764b2ac2-…5011
遷移（ア）      sessionID=764b2ac2-…5011
遷移（イ）      sessionID=764b2ac2-…5011
遷移（エ）      sessionID=764b2ac2-…5011
```

hidden の sessionID だけで管理し、**ログインの前後で値が同じ**。

設問1 の答え

a1＝（イ）ログインの遷移
ここで ID を変えるべきだった

a2＝https://test.△△△.jp/
sessionID を入手し、フォームを POST する先

（ア）はログイン失敗で 01 に戻る遷移、（エ）はログイン後の移動。

出典：IPA「情報処理安全確保支援士試験 科目Bのサンプル問題」問2 図2・表1・表B・設問1

セッションフィクセーションの手順と直し方

手順 1〜2
問合せ先のメールアドレスと、画面 01 の sessionID を手に入れる

手順 3〜5
その sessionID を付けて 01 へ自動 POST する HTML を罠サイトに置き、リンクをメールで送る

手順 6〜7
受信者が罠を開き、**M サイトにログイン**するのを待って（設問2）、同じ sessionID でアクセス

結果
応募者・問合せをした求職者の属性情報を閲覧される

設問3：直し方

使った sessionID を無効化し、新しい sessionID を発行	○
Cookie に HttpOnly・Secure・SameSite	**× Cookie を使っていない**
GET・URL パラメータで渡す	**× 漏れやすくなる**
暗号化してローカルストレージへ	**× 値は変わらない**

正解は 設問2 ア・設問3 キ（原文の記号）。

出典：IPA 科目Bのサンプル問題 問2 図A・設問2・設問3・解答例／IPA「安全なウェブサイトの作り方」1.4

Web の脆弱性と根本的な対策

脆弱性	見つけ方（事例の手がかり）	根本的な対策
CSRF	罠サイトから同じ POST を送らせると処理される	推測できないトークンを hidden に入れて照合
メールヘッダインジェクション	件名に %0d%0a と Bcc: を入れると別の宛先に届く	ヘッダは固定値、入力は本文へ。改行を除く
クリックジャッキング	透明な iframe で画面を重ねられる	X-Frame-Options か CSP frame-ancestors
認可制御の欠落	URL の番号を変えると他人の情報が見える	処理のたびに権限を確かめる

HttpOnly
JS から読めない（XSS）

Secure
HTTPS のときだけ送る

SameSite
他サイト発の要求に付けない

出典：IPA「安全なウェブサイトの作り方」改訂第7版 1.6・1.8・1.9・1.11

仕様のレビューと診断の計画

パスワード再設定の仕様（技能2-1）

- 推測できない URL（ランダム 32 字など）
- 短い有効期限・一度使ったら無効
- URL はメールだけで送る（画面に出さない）

> 利用者 ID を URL に入れる、新しいパスワードを画面に出す、は誤り。

ツールと手動の分担（技能2-6）

ツールが得意	手動が得意
既知の脆弱性の版	他人の ID に変えて見えるか
典型的な XSS・SQLi	手順を飛ばせるか
古い TLS の受付	業務の決まりに反する操作

> 診断は本番と同じ構成の検証用サイトで。開けたアクセス制限は戻す。

出典：シラバス案 技能2-1・2-6／IPA 科目Bのサンプル問題 問2 図1／OWASP Forgot Password Cheat Sheet

第3章

対策の適用とログ分析の事例

ログの並び方から、攻撃の種類を言い当てる。

ログを読む

プロキシログ:ビーコン通信

```
02:14:05 10.1.20.35 POST …check.top/index.php 312
02:15:05 10.1.20.35 POST …check.top/index.php 312
02:16:05 10.1.20.35 POST …check.top/index.php 312
```

> 深夜・60 秒ごと・同じ見慣れない宛先・同じ大きさ → C2 への定期通信。

認証ログ:失敗の並び方

```
09:00:01 198.51.100.7 user=aoki FAIL
09:00:31 198.51.100.7 user=ito  FAIL
09:02:03 198.51.100.7 user=ota  SUCCESS
```

1 ID × 多数のパスワード	ブルートフォース
多数の ID × 同じパスワード	**パスワードスプレー**
多数の ID × 漏えいした組	クレデンシャルスタッフィング

出典:シラバス案 技能1-5「ログ分析による設定不備や不正の検出」・技能3-4／ログは架空の例

技術的な対策を選ぶ

管理セグメント ＋ 踏み台サーバ
管理の通信を分け、入口を一つに。多要素認証と操作記録（3-5）

シークレット管理
鍵をソースに書かない。漏れたら**まず無効化して入れ替え**（3-1）

アカウントの棚卸
人事の情報と定期的に突き合わせ、利用部署が確認（3-8）

媒体の消去（NIST SP 800-88）

方法	SSD
ファイル削除・クイックフォーマット	× 残る
全体を 1 回上書き	△ 消し残り
メーカーのサニタイズ・暗号化消去	○
物理破壊	○

> Base64 は符号化で暗号ではない。ポート番号の変更は隠すだけ。

出典：NIST SP 800-88 Rev.1／シラバス案 技能3-1・3-3・3-5・3-8

第4章

インシデント対応の事例

広がりを止め、証拠を残し、期限までに報告する。

初動:トリアージと封じ込め

検知・受付
事実を確認
→
トリアージ
影響と緊急度
→
封じ込め
切り離す
→
根絶・復旧
→
報告・再発防止

トリアージで先にするもの

今も広がっている・社外に被害が出ている
例:公開サイトが改ざんされ閲覧者にマルウェアを配っている

後でよいもの
開かずに削除した不審メール、遮断済みのポートスキャン

ランサムウェアの最初の指示

LAN ケーブルを抜き、無線を切る
電源は入れたまま。画面を撮影し、操作しない

電源断・再起動・駆除はメモリの証拠を消す。身代金は払わない。

出典:JPCERT/CC「インシデントハンドリングマニュアル」・「侵入型ランサムウェア攻撃を受けたら読む FAQ」／シラバス案 技能4-2

証拠の保全と、法令の報告

揮発性の順序（RFC 3227）

レジスタ・キャッシュ

ルーティング表・ARP・プロセス表・メモリ

一時ファイル → ディスク

遠隔のログ → 物理構成 → 保管媒体

> 複製を取ってハッシュ値を記録し、調査は複製で。

漏えい等報告（個人情報保護法 第26条）

対象（規則 第7条）	要配慮／財産的被害のおそれ／不正の目的／1,000 人超
速報	速やかに（おおむね 3〜5 日以内）
確報（第8条）	30 日以内。**不正の目的は 60 日以内**

> 300 人でもカード番号の漏えいは報告対象。72 時間は GDPR。

出典：IETF RFC 3227 2.1／個人情報保護法 第26条・施行規則 第7条・第8条・ガイドライン（通則編）3-5-3／シラバス案 技能4-4

根本原因と、外部との連携

SQL インジェクションの再発防止（技能4-3）

直接の原因
文字列連結

→

根本原因
標準に決まりがない・レビューで見ない

再発防止
同じ作り方の全箇所をプレースホルダに。標準・レビュー・教育に反映

WAF の導入や、その画面だけの修正は暫定の対策。

情報セキュリティ早期警戒パートナーシップ

発見者 → **IPA** 受付 → **JPCERT/CC** 製品の調整 → **開発者** 修正・公表

社内では PSIRT が窓口になり、修正と公表の日を調整する。

出典：IPA「安全なウェブサイトの作り方」1.1／経済産業省告示「ソフトウエア製品等の脆弱性関連情報に関する取扱規程」／シラバス案 技能1-11・4-3